

安全漏洞审计报告 · 第3轮

用户信息管理平台 文件上传漏洞审计报告

User Management Platform — File Upload Security Assessment

目标系统：用户信息管理平台 (Flask)

报告日期：2026-07-09

漏洞等级：严重 × 1

修复状态：✅ 已修复

目录

1. 报告概述
2. 漏洞描述
3. 攻击演示（3 种攻击）
4. 修复方法
5. 修复前后对照
6. 修复验证
7. 全部三轮汇总

1. 报告概述

1.1 本轮背景

系统新增了"头像上传"功能，用户可以选择文件上传到 `/static/uploads/` 目录。由于没有做任何文件类型检查，且保留用户原始文件名，导致攻击者可以上传任意类型的恶意文件。

1.2 漏洞根因（一句话）

app.py 没有检查文件后缀名，也没有使用安全文件名，任何人都可以上传 **.html**、**.py**、**.exe** 等危险文件。

2. 漏洞描述

VULN-11 : 任意文件上传

● 严重

位置 : app.py — upload 路由

漏洞代码 :

```
f.save(os.path.join(upload_dir, f.filename)) ← 没有检查后缀, 没有处理文件名
```

问题 :

- ✗ 没有检查文件后缀 (.html、.py 都能上传)
- ✗ 没有使用安全文件名 (可能路径遍历)
- ✗ 上传的文件可通过 URL 直接访问
- ✗ 同名文件直接覆盖旧文件

3. 攻击演示

攻击 1：上传 HTML → XSS 攻击

🎯 攻击者上传一个包含 JS 的 HTML 文件

```
echo '<script>alert("你的Cookie:" + document.cookie)</script>' > hack.html  
curl -F "file=@hack.html;filename=hack.html" http://localhost:5000/upload
```

✅ 上传成功！文件保存到 /static/uploads/hack.html

👤 受害者访问这个链接

<http://localhost:5000/static/uploads/hack.html>

→ 浏览器执行 JS 脚本，Cookie 被窃取！

后果：攻击者可以窃取用户的登录 session，伪造身份登录系统。

攻击 2：上传 .py 文件

🎯 攻击者上传 Python 脚本

```
echo 'print("恶意代码")' > shell.py  
curl -F "file=@shell.py;filename=shell.py" http://localhost:5000/upload
```

✅ 上传成功！HTTP 200，无任何拦截

后果：如果服务器配置了解释器，.py 文件可能被远程执行。

攻击 3：上传 .bat / .exe 等危险文件

🎯 攻击者上传病毒文件

```
echo 'del C:\*.*' > virus.bat  
curl -F "file=@virus.bat;filename=virus.bat" http://localhost:5000/upload
```

✅ 上传成功！.bat .exe .dll 全部放行

后果：用户下载后运行，可能导致电脑中毒。

4. 修复方法

只需要添加 **3** 行代码：

4.1 检查文件后缀

```
# 只允许这几种图片格式 ALLOWED = {"png", "jpg", "jpeg", "gif", "webp"} ext =  
f.filename.rsplit(".", 1)[-1].lower() if "." in f.filename else "" if ext not in ALLOWED:  
return render_template("upload.html", error="只允许上传图片文件")
```

4.2 使用安全文件名

```
from werkzeug.utils import secure_filename safe_name = secure_filename(f.filename) # 移除  
路径和特殊字符
```

这两步加在一起，攻击者的 **.html**、**.py**、**.bat** 文件就传不上来了。

5. 修复前后对照

✖ 修复前

```
f.save(os.path.join(upload_dir, f.filename))
```

- 危险文件可上传
- 路径遍历可攻击
- XSS 攻击可触发

✔ 修复后

```
if ext not in ALLOWED: 拒绝  
safe_name = secure_filename(f.filename)  
f.save(os.path.join(upload_dir, safe_name))
```

- 仅允许图片上传
- 文件名安全无害

6. 修复验证

#	测试	结果
1	上传 .png 图片 → 成功	✓ 通过
2	上传 .html 文件 → 被拒绝	✓ 通过
3	上传 .py 文件 → 被拒绝	✓ 通过
4	上传 .bat 文件 → 被拒绝	✓ 通过
5	路径遍历 ../../ → 被 safe_filename 拦截	✓ 通过

7. 全部三轮汇总

轮次	审计内容	漏洞数	严重	中危	状态
第 1 轮	密码安全	8	4	4	✓
第 2 轮	SQL 注入	2	2	0	✓
第 3 轮	文件上传	1	1	0	✓
合计		11	7	4	全部已修复

三条修复规则（初学者必记）

- 规则 1：只允许图片后缀（png/jpg/jpeg/gif/webp）
- 规则 2：用 `secure_filename()` 处理文件名
- 规则 3：永远不要相信用户上传的文件名和后缀

安全漏洞审计报告 · 第3轮 — 文件上传安全 | 报告日期：2026-07-09

项目地址：<https://github.com/sencly-book/user-management>